

AJTES TCHAD — SÉCURITÉ

INFORMATIQUE

Rapport d'Architecture, Protection des Données & Guide d'Administration

VERSION OFFICIELLE 2026

Siège Social N'Djamena

Organisation : Association des Jeunes Tchadiens pour l'Éducation et la Solidarité (AJTES)

Responsable Technique & Maintenance : SALOMON (Super Admin - Contrôle 100%)

Périmètre d'Audit : API Backend (Node.js/Express) & Application Frontend (React/TypeScript)

Statut de Conformité : 100% Fonctionnel & Sécurisé

1. AUDIT DÉTAILLÉ DES DISPOSITIFS DE SÉCURITÉ

1 Hachage Irréversible des Mots de Passe `bcryptjs` (Cost 10)

Aucun mot de passe n'est stocké en texte clair. Chaque mot de passe est haché de manière irréversible avec un sel aléatoire. Même en cas d'accès non autorisé à la base de données, la récupération des mots de passe originaux est mathématiquement impossible.

2 Authentification Sécurisée par Tokens Chiffrés `jsonwebtoken` (JWT)

L'authentification utilise des jetons cryptographiques signés avec une clé secrète (JWT_SECRET). Le

middleware de vérification contrôle chaque requête protégée. Tout jeton modifié ou expiré est rejeté

immédiatement.

3 Contrôle d'Accès Basé sur les Rôles (RBAC) `role.middleware.ts`

Séparation stricte des privilèges : les fonctions d'administration (gestion des membres, validation

d'adhésion, modification de projets) sont protégées par le middleware de rôle et réservées exclusivement

aux comptes admin et super_admin.

4 Protection Anti-Brute Force (Rate Limiting) `rateLimit.middleware.ts`

Limitation automatique des tentatives de connexion et d'inscription à **15 requêtes maximum par**

tranche de 15 minutes par adresse IP. Protège l'application contre le piratage par dictionnaire et le déni

de service.

5 Alertes de Connexion en Temps Réel `email.service.ts`

Un e-mail de sécurité est automatiquement envoyé à l'utilisateur lors de chaque connexion réussie,

mentionnant la date et l'horodatage exacts, lui permettant de réagir immédiatement en cas d'activité

suspecte.

6 Protection contre les Injections SQL `Prisma ORM & SQLite`

Toutes les requêtes de base de données passent par l'ORM Prisma avec des requêtes paramétrées, ce qui

neutralise à 100% les attaques par injection SQL (SQLi).

7 Filtrage des Origines Réseau CORS Policy

Le serveur Backend rejette les requêtes provenant de domaines non autorisés. Seul le domaine frontend

officiel de l'association est autorisé à communiquer avec l'API.

8 Validation Strict des Formulaires Zod Schemas

Validation rigoureuse du type et du format de chaque donnée transmise (format e-mail, longueur de texte,

types numériques) avant tout traitement par le serveur.

9 Isolation des Clés Secrètes .env & .gitignore

Les secrets d'infrastructures (clés JWT, mots de passe SMTP, URLs de base de données) sont conservés hors

du code source et ne sont jamais publiés sur le dépôt GitHub public.

2. GUIDE PRATIQUE DE CONFIGURATION PAR SALOMON (SUPER ADMIN)

Comment modifier et contrôler la sécurité à votre niveau :

1. Changer la Clé Secrète JWT (Chiffrement des Jetons) :

Éditez le fichier `backend/.env` et modifiez la ligne `JWT_SECRET=VOTRE_CLÉ_PERSONNALISÉE`.

2. Ajuster le Seuil Anti-Brute Force (Rate Limiting) :

Dans `backend/src/middlewares/rateLimit.middleware.ts` , modifiez le paramètre `max: 15` pour ajuster le nombre d'essais de connexion autorisés.

3. Configurer l'Expédition Réelle des E-mails de Sécurité :

Dans `backend/.env` , renseignez vos identifiants Gmail `SMTP_USER=association.ajtes@gmail.com` et le mot de passe d'application `SMTP_PASS` .

4. Restreindre le Domaine Autorisé en Production (CORS) :

Dans `backend/.env` , définissez `CORS_ORIGIN=https://salomontchibkere.github.io` pour bloquer tout autre serveur.

5. Gérer les Rôles et Privilèges Administrateurs :

Directement depuis le code (`backend/src/seed.ts`) ou via le **Tableau de Bord Administration** sur le site.

3. MATRICE SYNTHÉTIQUE DE SÉCURITÉ

DOMAINE DE SÉCURITÉ	TECHNOLOGIE / FICHIER	NIVEAU DE PROTECTION	RISQUE CONTRÉ
Stockage Mots de Passe	bcryptjs	Élevé (Cost 10)	Vol de mots de passe en clair

DOMAINE DE SÉCURITÉ	TECHNOLOGIE / FICHIER	NIVEAU DE PROTECTION	RISQUE CONTRÉ
Authentification API	jsonwebtoken / auth.middleware.ts	Élevé (Signature secrète)	Usurpation d'identité & Vol de session
Gestion des Droits	role.middleware.ts	Élevé (RBAC)	Accès non autorisé aux fonctions admin
Attaques Réseau	rateLimit.middleware.ts	Élevé (15 req / 15 min)	Attaques Brute- Force & Dénis de service
Base de Données	Prisma ORM	Maximal (Requêtes paramétrées)	Injections SQL (SQLi)
Contrôle d'Origine	cors	Élevé (Origine restreinte)	Attaques Cross- Site Request Forgery